Unit 4- Q1 -**Describe** what a cyber security incident response plan is used for

NOTE:

You should be aware that the cyber security incident response plan also contains a checklist which is a vital part of the plan. The description and explanation should include reference to the checklist as well as the plan.

A cyber security incident plan is a set of instructions set out by the head IT/ cyber security specialist which are used to help the IT/ cyber security department work out what to do in case of a cyber-attack and how to recover from a cyber-attack. An incident response plan ensures that in the event of an attack there is a plan in place to deal with the threat and the security team knows what to do.

Unit 4- Q2 -**Explain** when a cyber security incident response plan is used

NOTE: You should be aware that the cyber security incident response plan also contains a checklist which is a vital part of the plan. The description and explanation should include reference to the checklist as well as the plan.

A cyber security incident response plan is used when an organisation suspects or confirms a cyber security incident that could threaten a system, data, network or users.
The plan provides a step-by-step guide for responding to an incident quickly and effectively
Identify what has happened and how serious
Contain the incident to prevent it from spreading
Eradication the threat such as removing malware or disabling compromised accounts
Recovery affected systems and return to normal
Document what happened and what actions were taken
Learn from the incident and improve security measures to reduce the chance of it happing again
If an employee receives an phasing email and accidently enters the password into a fake website the incident response plan may be activated. The IT/ security team could disable the compromised account reset passwords investigate whether the attack accessed other systems cheek for suspicious activity and restore normal access.

Unit 4- Q3 -**Describe** the stages of a cyber security incident response lifecycle

NOTE:

You should be aware that the cyber security incident response plan also contains a checklist which is a vital part of the plan. The description and explanation should include reference to the checklist as well as the overall plan.

Incident response lifecycle – there are a number of published incident response lifecycles available, you must describe one of them.
One example of an incident response lifecycle is

1.Preparation: A company prepares for a potential cyber security incident before they occur. This includes creating or reviewing policy carrying out risk assessment identified sensitive assets.

2. Identification: The IT team tracks and identifies any abnormalities within the network.

3. Containment: The malware is contained to one part of the network.

4. Eradication: Remove malware from all infected devices & identified the root cause.

5. Recovery: the affected system is put back online

6. Lessons learned: fixed all the problems that allowed the cyber-attack.

Unit 4- Q4 -**Explain** why it is important to maintain an up-to-date cyber security incident log

Maintain an up-to-date cybersecurity incident log is essential because it enables a company to identify threats quickly and respond before further damage occurs. Recording incidents accurately allows the security team to recognise pattens and understand which system, users or processes may be at risk. It also provides a record of what happened, when it happened and what actions were taken, which is useful when investigating the cause and impact of an attack. Keeping the log update helps the company learn from previous incidents and improves its security measures to reduce the chance of similar attack happening again. It can also provide evidence for audits and help the company meet relevant legal and regulatory requirements.

Unit 4- Q5 -**Explain** the steps to be included within a cyber security incident response plan

1.Preparation: a company prepare for cyber security incidents before they happen.

2. Identification: the plan should explain how a suspected security incident is identified and reported

3. Containment: once an incident has been reported the organisation should assess how serious it is

4. Eradication: the company should explain how they will contain the incident to prevent further damage

5. Recovery: the plan should explain how affected system will be safely restored

6. Lessons learned: after the incident has been resolved the company should review what happened and how effectively it responded.

Unit 4- Q6 -Explain why it is important to have a cyber security incident response plan

Having a cyber security incident response plan is important because it ensures a company knows what actions to take during a cyber security incident and who is responsible for each task. A quick and organised response can limit the spread of malware, data breaches and unauthorised access, reducing the damages caused. It also helps reduce downtime by allowing affected systems and services to be restored more quickly. The plan gives staff clear responsibilities, including who should investigate the incident, who needs to be informed and who has the authority to make decisions. It also helps protect sensitive customer, employee and business information from being stolen or exposed. By following an established procedure, staff can respond consistently under pressure rather than making decisions without guidance. Overall, having a response plan can reduce financial losses and reputational damage and help the company learn from the incident to prevent similar attacks in the future.

Unit 4- Q7 -Develop a cyber security incident response plan for an organisation

cyber security incident response plan

Purpose of the plan: The purpose of this plan is to make sure a company can respond quickly to cyber security incidents, such as malware infections, phishing attacks, data breaches or unmortised access. The aim is to limit damage, protect sensitive information, restore normal service and reduce financial and reputable losses.

Roles & Responsibilities

All employees: report any subspinous emails, unusual computer activity or security incidents to the IT department as soon as possible.

IT security team: Investigate the incident, assess its severity, collect evidence and take appropriate steps to contain the threat.

IT manager: Coordinate the response, decide on actions within their authority and escalate serious incidents to senior management

Senior management: Approve major decisions, such as shutting down important systems, and make sure the organisations has the resources needed to respond.

HR, Legal & communication teams: Provide support where employee information, legal requirements or communications with customers and the public are involved.

Reporting & recording incidents

When an incident is discovered, the employee must report it to the IT team immediately. The team will create an incident log containing the date & time the person reporting it says, the systems affected, the type of incident the suspected cause, the impact and action taken. The log must be kept up to date throughout the investigation. Relevant evidence, such as system logs and suspicious files, should be preserved securely so that it can be examined later.

Assessing the severity of the incident

The IT team will use a traffic light system to prioritise incidents.

Green- Low severity: A minor incident affecting one user or device, with little or no impact on business operations.

Amber- Medium severity: An incident affecting several users, a business application or potentially sensitive info.

Red- High severity: A major data breach, widespread malware infection, ransomware attacks or serious disruptions to business. Senior management must be notified immediately, and the IT team must take urgent action.

The severity level can be changed if the investigations reveal that the incident is more serious the first thought.

Steps for responding to an incident

Step 1: Detection & Reporting- The person who discovered the incident must contact the IT security team. The team will record the details and begin an initial investigation to establish what may have happened.

Step 2: Investigation & Assess- The IT team will examine available info to identify the type of attack, the systems affected, whether information has accessed or stolen, and the likely impact on the organisation. Evidence must be Recorded & Preserved.

Step 3: Contain the incident- The team will take suitable cation to prevent the incident from spreading. This could include disconnect an infected computer form the network, disabling a compromised account or blocking malicious network traffic. Major action that could affect business operations must be approved by an authorised manager, unless the plan allows the security team to act immediately.

Steps 4: Remove the threat- Once the incident is contained, the team will remove malware, close the venerability or disable the unauthorised access route allowed the incident to happen. Systems should be checked to make sure the threat has been removed.

Step 5: Recover systems & services- Affected systems will be restored safely, using clean backups where necessary. The IT team will test the systems, check that security control is working and monitor for signs that the attacker has returned. Important business services should be restored in controlled order.

Step 6: inform relevant people- The IT management & senior management must receive updates about the incident and its impact. Where necessary, the company will contact affected employs, customers, suppliers, legal advisers, insures or relevant authorities. Any reporting must follow the applicable legal and regulatory requirements and deadlines.

Step 7: Review the incident – After the incident has been resolved, the organisation will hold a review to establish what happened, how the attack occurred, hat worked well and what could be improved. The findings will be documented, and the incident response plan and security measures will be updated where needed.

Unit 4- Q8 -Explain what is meant by incident postmortem

It's a blameless review conducted after an incident to analyse what happened, why it happened, and how it happened and how to prevent similar issues in the future.

incident postmortems a formal process used to review operations, security or technical incident after they have been resolved and only after the incidents been resolved. Primary purpose is not to assign blame but to identify the root cause.

Unit 4- Q9 -Explain the structure of an incident postmortem

Incident Summary: is the overall cause of the problem. This includes the main points of the incident on a short section or page instead of making someone read through a very long report just to understand what happened.

Lead Up: how do the problem happen e.g. did someone click a dogy link and cause it or something.

Fault: what went wrong and what caused the incident for example, did someone click a link thinking it was something else.

Impact: overall impact on the company. For example, the company's files were encrypted and made the finance people lose access to the payment system.

Detection: how long was it unnoticed for and how long did it take to be resolved. For example, it took 30mins for the system to notice something strange and notify the department.

Response: how did the company react to a cyber breach and how did it respond. For example, did they over lode the report system issue or did they follow the company cyber guidelines.

Unit 4- Q10 - Consider the importance of the following when carrying out an incident postmortem:

• integrity • rigour • discipline.

Integrity is important when carrying out a postmortem because the people need to need to be honest about what happened.

Rigour is important because needs to be investigated properly. Evidence should be checked and the people investigating should look at timeline loges, systems and actions that happened during the incident.

Discipline is important because the postmortem needs to follow a proper process. The people involved need to collect the correct info, records what's happened and make sure actions are followed up.

Unit 4- Q11 -**Create** a postmortem report of an incident

Incident Postmortem Report – Phishing Email

Incident Summary

A member of staff received a phishing email on the 1st of October at 9:00 that appeared to be a genuine company email. The employee clicked on the link in the email and was taken to a fake login page. The incident was detected after unusual activity was noticed on the account.

Lead Up

The reconstructed timeline is

At 9:00 the employee resived an email

At 9:05 the employee opened the email

At 9:11 the employee entered their login info

At 9:15 the attack begun

At 9:20 the IT people noticed unusual activity

At 9:55 the attack was stopped

Fault

The main fault was that the malicious attachment was able to run on the employee's laptop. The employee also had access to a shared file server which the malware was able to reach. The email security system did not block the email and the security alert happened after the suspicious activity had already started

Impact

The ransomware affected one employee laptop and one file server. Around 6,500 internal files were temporarily unavailable because they had been encrypted. The Finance staff were unable to work normally for around four hours.

Detection

The incident was detected when the security system sent an alert because it noticed unusual processes and file activity on the Finance laptop. IT then noticed unusual access to the shared file server.

Response

The first response was to disconnect the affected laptop from the network and isolate the file server. The employee's account was temporarily disabled and active sessions were stopped. Passwords were reset and the company's access credentials were checked.

Recovery

The affected laptop was rebuilt using a trusted image. The file server was checked and patched before the data was restored from a clean backup made before the attack. The restored files were tested before the server was put back into normal use.

Root Cause

The initial cause of the attack was the malicious email attachment. However, the investigation found that there were other problems that helped the incident become worse. These included not having enough protection against malicious email attachments, the employee having more access to shared resources than was necessary and not having enough regular security awareness training.

Lessons Learned

The main lessons from the incident are that the company's email security needs to be improved and staff need regular training on phishing and malicious attachments.

Unit 4- Q12 - Reflect upon the report and make recommendations based on the findings

The incident was successfully stopped and the services restored but the postmortem revealed serval areas for improvements. The company will use what it learned to make sure this never happens again.

1. Initial Access - How it gets in:

Phishing: Malicious attachment or link in email / Teams / SMS

Drive-by Download: You visit a compromised website and it silently downloads malware

Exploiting Public-Facing Apps: Using unpatched vulnerabilities (e.g. Log4j, Microsoft Exchange)

Supply Chain: Infecting software update from a trusted vendor

Removable Media / USB drops

2. Execution & Persistence - How it stays:

Registry Run Keys / Startup Folder: Adds itself to autostart

Scheduled Task: Creates a task to re-launch every reboot

Bootkit: Infects the boot sector before Windows even starts

Process Injection: Hides its code inside a legitimate process like explorer.exe

3. Privilege Escalation & Defense Evasion:

Living off the Land (LotL): Uses legitimate Windows tools like PowerShell, to avoid detection

Obfuscation / Packing: Scrambles its code so antivirus can't recognize it

Disabling Defender / Firewall: Kills your security tools

UAC Bypass: Gets admin rights without prompting you

4. Credential Access & Discovery:

Credential Dumping: Steals passwords from memory (Mimikatz technique)

Keylogging & Clipboard Stealing

Network Scanning: Looks for other vulnerable devices to spread to

5. Lateral Movement:

Pass-the-Hash: Uses stolen password hashes to log into other PCs without needing the real password

Exploiting SMB Worm-like spread inside a company network

6. Data theft /Exfiltration & Impact:

Data Exfiltration: Uploads your files to attacker-controlled cloud storage

Command and Control (C2): Connects back to attacker server via HTTPS, DNS tunneling to get instructions

Encryption / Destruction: Final ransomware or wiper stage